

PROGETTO W12D4

ALUNNO: MAZZI EMANUELE

TRACCIA:

Effettuare una scansione completa della macchina Metasploitable tramite Nessus. Identificare da 2 a 4 vulnerabilità critiche presenti sul sistema e implementare delle azioni di remediation per ridurre o mitigare i rischi individuati.

Successivamente eseguire una nuova scansione sul target per verificare l'efficacia delle modifiche apportate e confrontare i risultati ottenuti prima e dopo la remediation.

Verifica della connettività

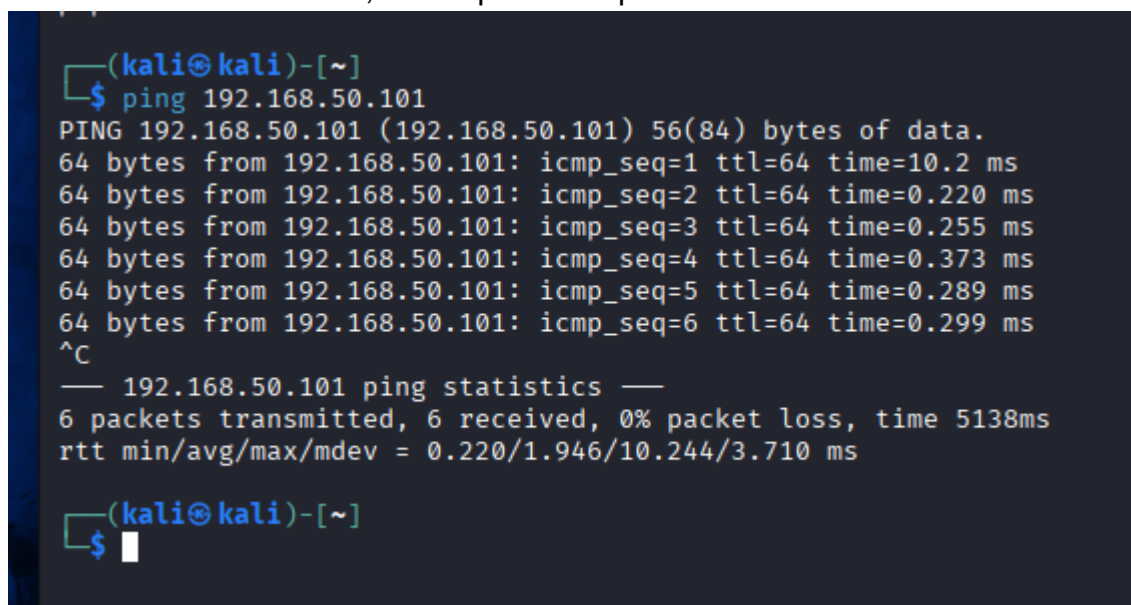
Prima di iniziare le attività di Vulnerability Assessment ho verificato la corretta comunicazione tra la macchina Kali Linux e il target Metasploitable.

Le due macchine erano configurate all'interno della stessa rete interna:

Kali Linux → 192.168.50.100

Metasploitable → 192.168.50.101

Tramite il comando ping ho verificato che il target fosse raggiungibile correttamente dalla macchina Kali Linux, senza perdita di pacchetti.



```
(kali㉿kali)-[~]  
$ ping 192.168.50.101  
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data:  
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=10.2 ms  
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=0.220 ms  
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=0.255 ms  
64 bytes from 192.168.50.101: icmp_seq=4 ttl=64 time=0.373 ms  
64 bytes from 192.168.50.101: icmp_seq=5 ttl=64 time=0.289 ms  
64 bytes from 192.168.50.101: icmp_seq=6 ttl=64 time=0.299 ms  
^C  
— 192.168.50.101 ping statistics —  
6 packets transmitted, 6 received, 0% packet loss, time 5138ms  
rtt min/avg/max/mdev = 0.220/1.946/10.244/3.710 ms  
  
(kali㉿kali)-[~]  
$
```

Avvio di Nessus

Dopo aver verificato la connettività tra le macchine, ho avviato il servizio **Nessus** sulla macchina Kali Linux.

Per verificare il corretto funzionamento del vulnerability scanner ho controllato lo stato del servizio **nessusd**, verificando che risultasse attivo e in esecuzione.

```
(kali@kali)-[~]
$ sudo systemctl start nessusd
[sudo] password di kali:

(kali@kali)-[~]
$ sudo systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/usr/lib/systemd/system/nessusd.service; disabled; preset: disabled)
   Active: active (running) since Tue 2026-05-12 13:44:32 EDT; 10s ago
  Invocation: 0b4db090bbe04b238279df4c40847484
    Main PID: 7665 (nessus-service)
      Tasks: 21 (limit: 5046)
     Memory: 766.9M (peak: 766.9M)
        CPU: 22.587s
       CGroup: /system.slice/nessusd.service
               └─7665 /opt/nessus/sbin/nessus-service -q
                 └─7667 nessusd -q

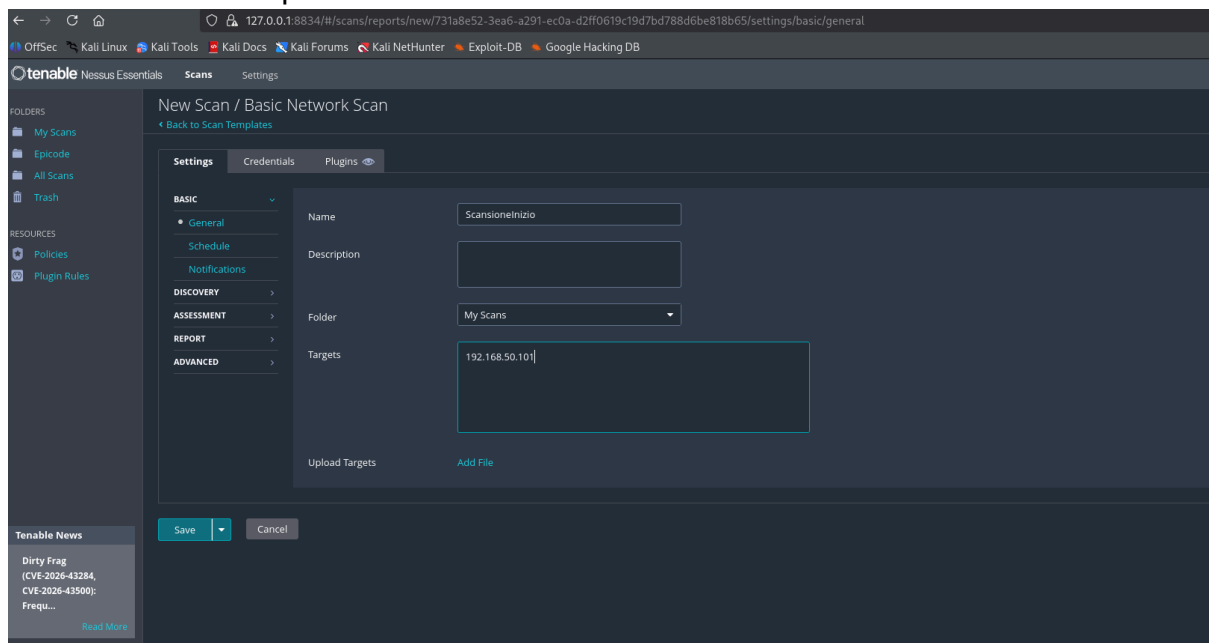
mag 12 13:44:32 kali systemd[1]: Started nessusd.service - The Nessus Vulnerability Scanner.
mag 12 13:44:32 kali nessus-service[7665]: nessus-service [7665][INFO] : Nessus 19.16.3 [build 20047] Started
```

Scansione iniziale con Nessus

Dopo aver avviato il servizio Nessus sulla macchina Kali Linux, ho effettuato l'accesso all'interfaccia web del vulnerability scanner.

Successivamente ho creato una nuova scansione utilizzando il template “Basic Network Scan”, impostando come target la macchina Metasploitable con indirizzo IP 192.168.50.101.

Questa scansione aveva l'obiettivo di identificare le vulnerabilità presenti sul sistema e i relativi servizi esposti.



Risultati della scansione iniziale

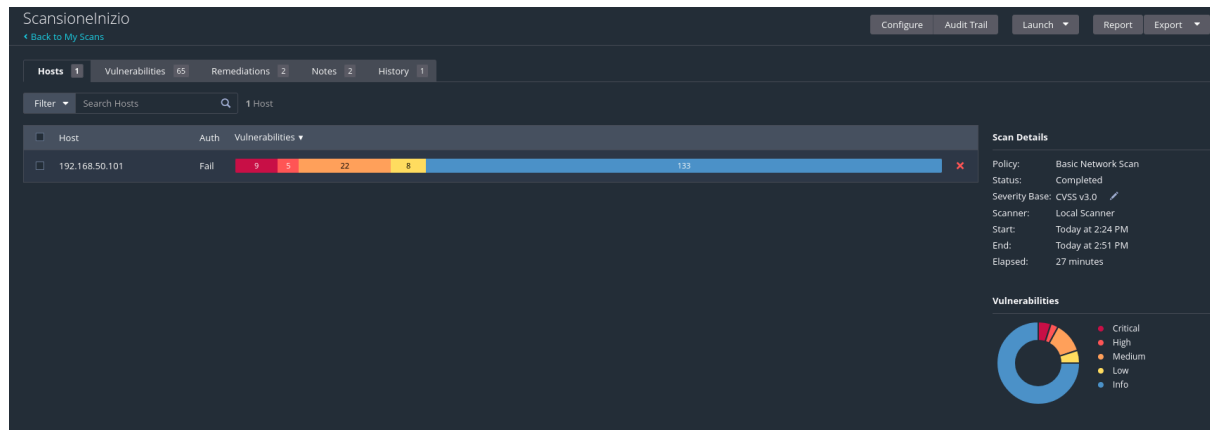
Una volta completata la scansione tramite Nessus, sono state individuate diverse vulnerabilità presenti sulla macchina Metasploitable.

Il vulnerability scanner ha identificato:

9 vulnerabilità Critical

5 vulnerabilità High
22 vulnerabilità Medium
8 vulnerabilità Low

Dopo aver analizzato i risultati ottenuti, ho deciso di concentrarmi sulle vulnerabilità critiche maggiormente esposte e più semplici da mitigare direttamente sul sistema.



Vulnerabilità identificate

Analizzando i risultati della scansione iniziale sono state individuate diverse vulnerabilità critiche e ad alto rischio presenti sulla macchina Metasploitable.

Tra le vulnerabilità rilevate ho deciso di concentrarmi principalmente su:

VNC Server 'password' Password
Bind Shell Backdoor Detection
NFS Shares World Readable
SSL Version 2 and 3 Protocol Detection

Queste vulnerabilità espongono il sistema a rischi legati ad accessi non autorizzati, utilizzo di protocolli obsoleti ed esposizione di servizi vulnerabili.

ScansionelInizio / 192.168.50.101

Configure Audit Trail Launch Report Export

Vulnerabilities 65

Filter Search Vulnerabilities 65 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
CRITICAL	10.0			Canonical Ubuntu Linux SEoL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
CRITICAL	9.8	8.9	0.9447	Apache Tomcat AJP Connector Request Injection (Ghostcat)	Web Servers	1	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
HIGH	7.5	5.9	0.7852	Samba Badlock Vulnerability	General	1	
HIGH	7.5			NFS Shares World Readable	RPC	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	29	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	5	
MEDIUM	6.5			TLS Version 1.0 Protocol Detection	Service detection	2	
MEDIUM	5.9	4.4	0.027	SSL Anonymous Cipher Suites Supported	Service detection	1	

Host Details

IP: 192.168.50.101
MAC: 08:00:27:56:7F:2E
OS: Linux Kernel 2.6 on Ubuntu 8.04 (hardy)
Start: Today at 2:24 PM
End: Today at 2:51 PM
Elapsed: 27 minutes
KB: Download
Auth: Fail

Vulnerabilities

Donut chart showing vulnerability distribution: Critical (5), High (5), Medium (22), Low (8), Info (133).

Verifica del servizio VNC

Dopo aver analizzato i risultati della scansione Nessus, ho verificato la presenza del servizio VNC vulnerabile direttamente sulla macchina Metasploitable.

Tramite il comando **netstat -tulnp | grep 5900** ho confermato che il servizio risultava in ascolto sulla porta 5900, utilizzata normalmente dai server VNC per l'accesso remoto.

```
msfadmin@metasploitable:~$ netstat -tulnp | grep 5900
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:5900        0.0.0.0:*          LISTEN
msfadmin@metasploitable:~$
```

Identificazione del servizio VNC vulnerabile

Dopo aver verificato la presenza della porta 5900 in ascolto tramite netstat, ho analizzato i processi attivi presenti sulla macchina Metasploitable.

Tramite il comando **ps aux | grep vnc** ho identificato il processo **Xtightvnc**, confermando la presenza di un server VNC attivo ed esposto sulla rete.

```
msfadmin@metasploitable:~$ ps aux | grep vnc
root      4586  0.0  2.3 13924 12060 ?        S    13:35   0:01 Xtightvnc :0 -d
esktop X -auth /root/.Xauthority -geometry 1024x768 -depth 24 -rfbwait 120000 -r
fbauth /root/.vnc/passwd -rfbport 5900 -fp /usr/X11R6/lib/X11/fonts/Type1/,/usr/
X11R6/lib/X11/fonts/Speedo/,/usr/X11R6/lib/X11/fonts/misc/,/usr/X11R6/lib/X11/fo
nts/75dpi/,/usr/X11R6/lib/X11/fonts/100dpi/,/usr/share/fonts/X11/misc/,/usr/shar
e/fonts/X11/Type1/,/usr/share/fonts/X11/75dpi/,/usr/share/fonts/X11/100dpi/ -co
n/etc/X11/rgb
root      4590  0.0  0.2   2724   1184 ?        S    13:35   0:00 /bin/sh /root/.
vnc/xstartup
msfadmin  5946  0.0  0.1   3004    756 tty1    R+   16:21   0:00 grep vnc
msfadmin@metasploitable:~$
```

Remediation VNC Server 'password' Password

Dopo aver identificato il processo **Xtightvnc** attivo sulla macchina Metasploitable, ho deciso di interrompere il servizio vulnerabile per ridurre l'esposizione del sistema.

Tramite il comando **kill -9** ho terminato il processo associato al server VNC.

Successivamente ho verificato nuovamente i processi attivi presenti sul sistema, confermando che il servizio VNC non risultava più in esecuzione.

```
msfadmin@metasploitable:~$ sudo kill -9 4586
msfadmin@metasploitable:~$ ps aux | grep vnc
msfadmin  5951  0.0  0.1   3004    752 tty1    R+   16:24   0:00 grep vnc
msfadmin@metasploitable:~$
```

Identificazione della Bind Shell vulnerabile

Analizzando le vulnerabilità critiche individuate da Nessus, ho verificato la presenza di una bind shell attiva sulla macchina Metasploitable.

Tramite il comando **netstat -tulnp | grep 1524** ho confermato che il sistema espose una shell remota in ascolto sulla porta 1524.

```
msfadmin@metasploitable:~$ netstat -tulnp | grep 1524
(No info could be read for "-p": geteuid()=1000 but you should be root.)
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN
```

Analisi del servizio vulnerabile

Per approfondire l'analisi della bind shell rilevata da Nessus, ho controllato i processi associati ai servizi di rete presenti sulla macchina Metasploitable.

Tramite il comando **ps aux | grep inetd** ho identificato il servizio **xinetd**, utilizzato per la gestione di diversi servizi remoti vulnerabili presenti sul sistema.

```
msfadmin@metasploitable:~$ ps aux | grep inetd
root      4419  0.0  0.1  2424  860 ?        Ss   09:19   0:00 /usr/sbin/xinetd -pidfile /var/run/xinetd.pid -stayalive -inetd_compat
msfadmin  4682  0.0  0.1  3004  756 tty1    R+   09:28   0:00 grep inetd
```

Remediation Bind Shell Backdoor Detection

Dopo aver identificato il servizio xinetd associato alla bind shell vulnerabile, ho deciso di interrompere il processo per impedire l'esposizione della shell remota sulla rete.

Tramite il comando **kill -9** ho terminato il processo xinetd.

Successivamente ho verificato nuovamente le porte in ascolto sul sistema, confermando che la porta 1524 non risultava più attiva.

Identificazione della configurazione NFS vulnerabile

Per verificare la vulnerabilità relativa alle condivisioni NFS ho analizzato il file `/etc/exports`, utilizzato dal sistema per definire le directory condivise tramite NFS. All'interno del file era presente una configurazione estremamente permissiva:

/(rw,sync,no_root_squash,no_subtree_check)

Questa configurazione permetteva a qualsiasi host della rete di accedere alla condivisione NFS con privilegi elevati.

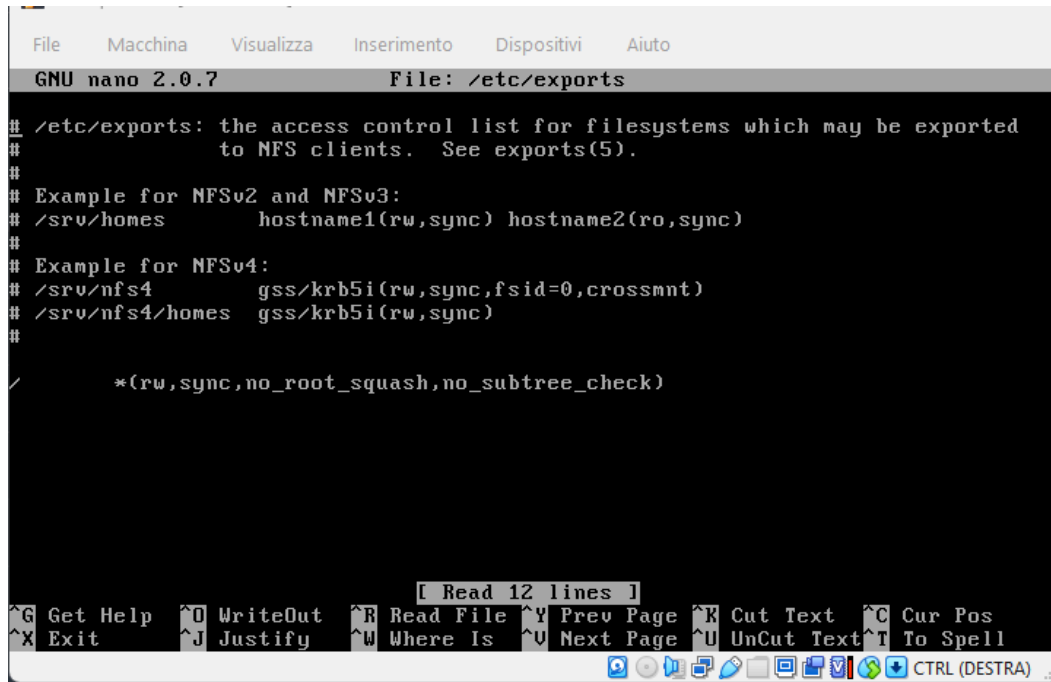
```
msfadmin@metasploitable:~$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#               to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
/               *(rw,sync,no_root_squash,no_subtree_check)
msfadmin@metasploitable:~$
```

Remediation NFS Shares World Readable

Dopo aver identificato la configurazione vulnerabile presente nel file `/etc/exports`, ho deciso di disabilitare la condivisione NFS esposta sulla rete.

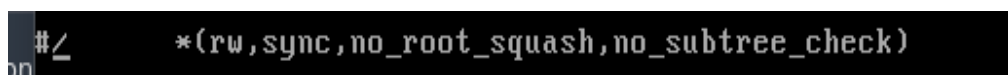
Per mitigare il problema ho commentato la regola vulnerabile presente nel file di configurazione, impedendo così l'accesso non autorizzato alla condivisione.

Successivamente ho applicato le modifiche tramite il comando **exportfs -ra** , aggiornando la configurazione del servizio NFS sul sistema.



```
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
GNU nano 2.0.7  File: /etc/exports

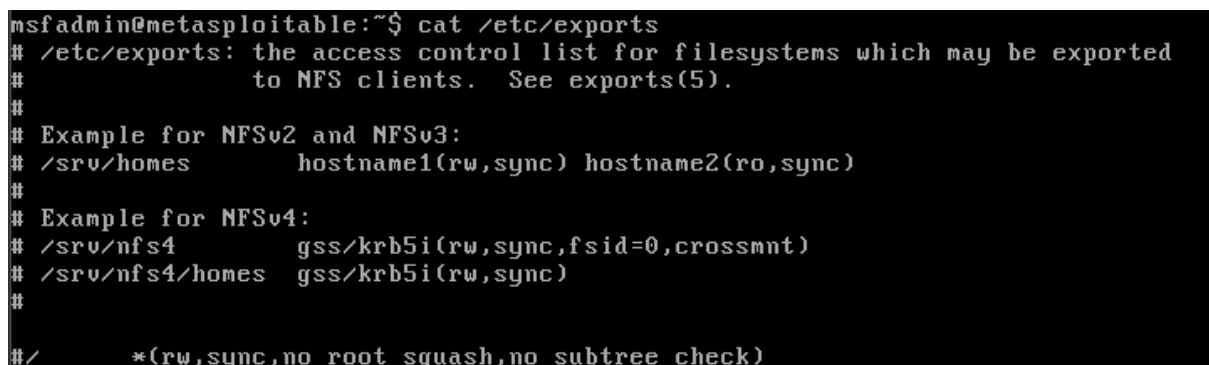
# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
#
# *(rw,sync,no_root_squash,no_subtree_check)
```



```
# / * (rw,sync,no_root_squash,no_subtree_check)
```



```
msfadmin@metasploitable:~$ sudo exportfs -ra
```



```
msfadmin@metasploitable:~$ cat /etc/exports
# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
#
# *(rw,sync,no_root_squash,no_subtree_check)
```

Identificazione del servizio SSL vulnerabile

Per verificare la presenza di servizi HTTPS esposti sul sistema ho eseguito il comando:

netstat -tulnp | grep 443

Il controllo non ha mostrato servizi direttamente in ascolto sulla porta 443. Nonostante ciò, Nessus ha rilevato il supporto a protocolli SSL obsoleti tramite altri servizi legacy presenti sulla macchina Metasploitable.

Remediation SSL Version 2 and 3 Protocol Detection

Dopo aver verificato l'assenza di servizi HTTPS direttamente esposti sulla porta 443, ho deciso di ridurre l'esposizione dei servizi legacy presenti sulla macchina Metasploitable.

Per mitigare la vulnerabilità ho verificato che il servizio xinetd, utilizzato per la gestione di diversi servizi remoti vulnerabili, risultasse disabilitato dopo le modifiche effettuate durante le precedenti attività di remediation.

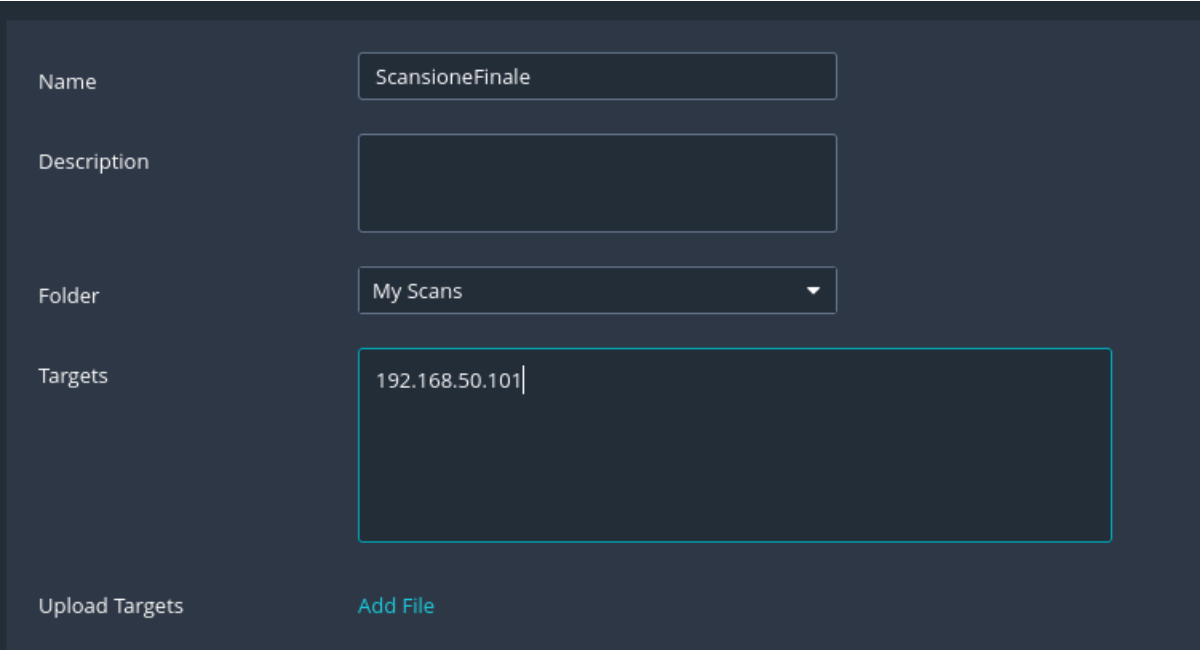
Questa operazione ha contribuito a limitare l'esposizione dei protocolli SSL obsoleti rilevati da Nessus durante la scansione iniziale.

```
msfadmin@metasploitable:~$ netstat -tulpn | grep 443
(No info could be read for "-p": geteuid()=1000 but you should be root.)
msfadmin@metasploitable:~$ ps aux | grep inetd
msfadmin  4723  0.0  0.1  3004  752 tty1      R+   09:46   0:00 grep inetd
msfadmin@metasploitable:~$
```

Scansione finale dopo le remediation

Dopo aver completato le attività di remediation ho creato una nuova scansione Nessus chiamata ScansioneFinale.

Ho nuovamente analizzato la macchina Metasploitable con l'obiettivo di verificare l'efficacia delle modifiche applicate e confrontare i risultati ottenuti rispetto alla scansione iniziale.



The screenshot shows the Nessus configuration interface for a new scan. The 'Name' field is set to 'ScansioneFinale'. The 'Description' field is empty. The 'Folder' is set to 'My Scans'. The 'Targets' field contains the IP address '192.168.50.101'. At the bottom, there are two buttons: 'Upload Targets' and 'Add File'.

Name	ScansioneFinale
Description	
Folder	My Scans
Targets	192.168.50.101

Upload Targets Add File

Confrontando i risultati ottenuti con quelli della scansione iniziale è stato possibile osservare una riduzione del numero di vulnerabilità critiche e ad alto rischio presenti sul sistema.

In particolare:

le vulnerabilità Critical sono passate da 9 a 6;

le vulnerabilità High sono passate da 5 a 4;

le vulnerabilità Low sono diminuite da 8 a 7.

Questo ha confermato l'efficacia delle modifiche applicate durante le attività di remediation.

Conclusioni

Questo laboratorio mi ha permesso di applicare concretamente le attività di Vulnerability Assessment e remediation affrontate durante il corso.

Tramite Nessus sono riuscito ad identificare diverse vulnerabilità critiche presenti sulla macchina Metasploitable, legate principalmente a servizi legacy vulnerabili, configurazioni insicure ed esposizione non necessaria di servizi di rete.

Durante le attività di remediation ho analizzato i processi e le configurazioni presenti sul sistema, intervenendo direttamente sui servizi vulnerabili per ridurre l'esposizione.

In particolare ho:

- disabilitato il server VNC vulnerabile;
- interrotto la bind shell esposta sulla porta 1524;
- modificato la configurazione NFS presente nel file /etc/exports;
- ridotto l'esposizione dei servizi legacy associati ai protocolli SSL obsoleti.

Infine, tramite una seconda scansione Nessus, ho verificato l'efficacia delle modifiche applicate, osservando una riduzione del numero di vulnerabilità critiche presenti sul sistema.

Questo esercizio mi ha permesso di comprendere meglio il funzionamento di Nessus e l'importanza delle attività di remediation nella riduzione della superficie di attacco di un sistema vulnerabile.